CloudDesk Technologies

Incident Response Plan

1. Authority, scope and response roles

SYNTHETIC / DEMO - document control

CD-IRP-001 | Version 1.0 | Fictional effective date: 2026-10-22 | Next review: 2027-10-22. Owner and incident coordinator: Engineering Lead. Accountable approver: CTO; approval not recorded. Review annually and after material incidents, exercises or changes. This editable JSON is the source of truth for the generated PDF.

Status and assumptions

CloudDesk Technologies is a fictional 75-person B2B SaaS vendor. All requirements and roles here are proposed SYNTHETIC / DEMO assumptions, not operating facts. This model-authored plan has review_status: requires_user_review. No implemented controls, live reporting channels, completed response actions, notifications, successful restores, audit certifications or legal compliance conclusions are claimed.

Purpose and scope

Guide assessment, containment, eradication and recovery of suspected threats to confidentiality, integrity or availability of customer information and the hosted SaaS service. Scope includes employees, contractors, service identities, cloud accounts, production and corporate systems, endpoints, vendors and backups. Coordinate service continuity and customer impact decisions with information_security_policy.pdf; encryption_key_management_policy.pdf remains authoritative for keys and encryption, and access_control_policy.pdf for access requirements.

Responsibilities and staffing

The CTO is accountable for material risk, resources, emergency authority and external communication authorization. The Engineering Lead coordinates triage, severity, assignments, the incident record and handovers. Platform Engineering and system owners perform assigned investigation and recovery; managers coordinate personnel matters. Seek qualified legal/privacy advice and specialist support when needed, without assuming retained providers or a staffed legal team. All personnel report suspicions. No dedicated or 24/7 SOC, on-call rota or guaranteed response time is assumed; the CTO must approve coverage, substitutes and contact routes before operational adoption.

Incident Response Plan

2. Reporting, classification and escalation

Proposed reporting routes

Proposed channels are an access-restricted incident ticket and direct contact with the Engineering Lead using a verified internal directory. These are design proposals, not live services or monitored addresses. If unavailable, contact the CTO or a designated substitute; if company accounts may be compromised, use a separately verified alternate contact method. Before adoption, validate contacts, coverage and escalation paths. Report promptly on discovery; do not wait to prove an incident or include passwords, tokens or unnecessary customer data in reports.

Event versus incident

An event is an observation such as a failed login, alert or outage that needs assessment. An incident is suspected or confirmed unauthorized access, disclosure, alteration, destructive activity or disruption requiring coordinated response. The Engineering Lead records classification and rationale, including false positives and routine faults. Uncertainty about significant harm warrants provisional incident handling; absence of confirmed exfiltration is not proof that no data was accessed.

Severity levels

SEV1 Critical: active widespread compromise, destructive cyber extortion, likely material customer data exposure or sustained loss of a critical service. Escalate directly to CTO and coordinate technical and continuity work immediately on recognition. SEV2 High: credible privileged credential/key compromise, limited suspected customer exposure or significant contained disruption; inform CTO promptly and assess specialist help. SEV3 Moderate: bounded single-system incident with no current evidence of privileged access or customer exposure; Engineering Lead directs response and informs CTO if scope grows. SEV4 Low: suspicious event or unsuccessful attempt without identified impact; record, assess and monitor, closing only with rationale.

Reassessment and handover

Severity is provisional. Raise severity for active spread, sensitive data access, tenant boundary failures, evidence tampering, key or backup compromise, uncertain containment, expanding outage or contractual/legal notification triggers. Record discovery and awareness times, affected scope, confidence, owner, severity changes, next check and decision rationale. The coordinator sets case-specific update intervals based on harm and responder availability; no fixed response guarantee is promised. Escalate unacknowledged urgent reports through verified alternates; explicitly hand over evidence, decisions and outstanding risks between responders.

3. Triage and evidence preservation

Initial assessment

Open a unique incident ID. Record reporter, discovery time and timezone, observed symptoms, affected systems, tenants, information classes and service dependencies. Separate observed facts from hypotheses. Assess attacker access, persistence, possible exfiltration, business impact and ongoing harm; identify evidence sources and disappearing logs. Use trusted administrative access and preserve relevant evidence before changes where safe. Do not delay urgent containment solely to collect evidence; record what was changed or lost and why.

Collection and chain of custody

An assigned custodian records each evidence item ID, source asset/account, collection method and tool/version, collector, UTC acquisition time, original timezone/clock uncertainty and incident ID. Preserve original exports read-only where supported; calculate and record a SHA-256 hash at acquisition and verify copies. For each transfer record sender, recipient, time, purpose, storage location and integrity check. Analyze working copies, retain provenance and document gaps. Hashes support integrity tracking and do not establish authenticity or legal admissibility by themselves.

Restricted evidence handling

Collect relevant identity, cloud control-plane, SaaS audit, application and KMS records plus snapshots when proportionate and authorized. Minimize personal/customer data and avoid copying plaintext secrets; restrict access to assigned responders, encrypt stored evidence and transfers, and record access. Agree retention and holds with appropriate advice and applicable obligations before disposal. Preserve the encryption policy minimum 12-month retention for KMS audit logs; do not extend that period automatically to all evidence. No existing log coverage or forensic readiness is asserted.

Investigation and decision log

Build a timeline linking evidence IDs to actions, indicators, affected identities, tenant scope and confidence. Record alternatives, approval, expected harm and rollback for significant response decisions. Verify suspicious instructions using known contacts; do not run attacker-provided tools. Preserve relevant vendor communications and request provider assistance through verified support routes. Assess collection authority and customer agreements before accessing tenant content. Record inaccessible sources and unresolved scope rather than declaring certainty.

Incident Response Plan

4. Containment, eradication and safe recovery

Containment authority and tradeoffs

Engineering Lead coordinates proportionate isolation of affected endpoints, workloads, sessions or network routes with system owners. Responders may take urgent reversible action to stop active harm, documenting scope and informing the coordinator and CTO. CTO authorizes material service shutdowns and residual-risk decisions; seek verified alternate approval if unavailable and record any unavoidable emergency decision for review. Preserve evidence where safe, evaluate customer impact and recovery dependencies, and avoid destructive cleanup before necessary collection.

Cloud, SaaS and identity compromise

Inspect cloud IAM, federated identity, OAuth grants, API tokens, service accounts, automation, exposed storage, suspicious rules and cross-tenant paths. Revoke affected sessions and grants, reset compromised credentials through trusted systems, rotate dependent secrets and remove unauthorized integrations. Assess persistence beyond password resets and coordinate with providers; shared responsibility does not remove CloudDesk investigation duties. Preserve unique user accounts, MFA for administrative access and quarterly access reviews. Revoke terminated employee access within 24 hours; this is an outer termination requirement, not permission to delay urgent compromise containment.

Key compromise and backup access

On suspected key compromise immediately open an incident, revoke affected identity grants and disable compromised key versions where safe under CD-ENC-001. Replace compromised certificate private keys immediately. Provision replacement keys and assess exposed data, historical re-encryption and backup recoverability; rotation alone does not re-encrypt historical data. Retain restricted older key versions while retained data/backups need them. CTO authorizes temporary emergency decrypt access with logging and next-business-day review. Destruction requires Engineering Lead and CTO approval after retention and recovery checks; never blindly delete keys to contain an incident.

Eradication and recovery gates

Identify root cause, remove persistence, patch or rebuild from trusted sources and validate configuration and replacement credentials. Preserve backup-specific key grants separate from ordinary application access. Before restoration assess backup integrity and compromise window, scan in isolation, test authorized decrypt access and validate data, tenant separation and critical service behavior. System owners propose phased reconnection, monitoring and rollback criteria; Engineering Lead verifies containment and CTO approves material residual risk and return of critical service. Follow approved RTO/RPO when established; none are numerically guaranteed here. Reopen investigation if indicators recur.

Incident Response Plan

5. Extortion, communications and notification decisions

Cyber extortion decisions

Treat ransomware, destructive threats and data-theft extortion as potential SEV1 incidents. Preserve demands and evidence, isolate affected paths and protect clean backups and recovery credentials. Do not authorize individual responders to negotiate, pay, promise secrecy or contact attackers. CTO coordinates decisions with qualified legal advice, appropriate leadership and relevant insurer/law-enforcement consultation where applicable. Assess safety, sanctions and other applicable restrictions, contractual duties, recoverability and alternatives; this plan pre-authorizes no payment. Payment or a decryption tool does not guarantee recovery, deletion or confidentiality. Document decisions and independently validate any proposed recovery tool in isolation.

Communication authorization

Engineering Lead maintains a factual internal situation report with known scope, uncertainty, actions proposed/taken in the incident and next review. CTO authorizes external/customer communications with relevant legal/privacy advice and an assigned spokesperson. Responders avoid speculation, attribution and unapproved statements. Use verified recipients and secure alternate routes if normal messaging is affected. Limit sensitive indicators and personal data to need-to-know recipients; retain approved versions, recipients and delivery evidence. This document records no actual communication or notification.

Customer and external notification assessment

Assess customer contracts, provider terms, applicable laws and affected jurisdictions case by case with qualified advice. Record when awareness arose, decision owner, relevant duty/trigger, affected parties, required content, deadline and calculation basis, uncertainty and approval. There is no universal notification deadline in this plan. Do not wait for perfect attribution or a completed investigation if an applicable duty requires earlier notice. Track evolving facts and supplemental updates, and document the basis for notification or non-notification. Consider regulators, affected individuals, customers, providers and law enforcement as applicable, without assuming every incident requires every recipient.

Continuity and customer support

Coordinate service status, workarounds, restoration priorities and support responses with system owners and the CTO. Assess customer impacts and contractual recovery commitments without promising unverified restoration times. Verify backup access is available only to authorized recovery roles and does not reconnect compromised identities. Record disputed facts and decisions to defer recovery; preserve required holds and evidence throughout communications and restoration.

Incident Response Plan

6. Closure, exercises and plan maintenance

Closure and lessons learned

Engineering Lead proposes closure after scope and residual uncertainties are documented, containment and recovery checks are recorded, notification decisions are tracked and remaining risks have owners. CTO reviews significant incidents and accepts material residual risk. Coordinate a blameless lessons-learned review after significant incidents: timeline, root cause, detection gaps, evidence quality, customer impact and response decisions. Assign corrective actions with owners, due dates, verification criteria and closure evidence; feed risks and overdue material actions into the risk register. Closure does not erase unresolved obligations or evidence holds.

Testing and awareness

Exercise incident scenarios at least annually alongside the information security policy annual continuity exercises and after material changes. Include cloud credential/key compromise, SaaS tenant exposure, extortion, unavailable responders and customer notification decisions. Use fictional data and isolated environments; record participants, assumptions, findings and corrective actions. Preserve the encryption policy requirement for a representative encrypted restore at least quarterly, checking integrity, authorized key access and outcome. Managers arrange security awareness at onboarding and annually, including incident reporting and phishing. None of these exercises or training activities is claimed completed.

Records, exceptions and review

Keep incident records, evidence inventories, custody transfers, decision logs, approvals, notification assessments, recovery checks and follow-up records in an access-restricted repository under approved retention and hold rules. Engineering Lead reviews this plan annually and after significant incidents or changes, verifies proposed contact routes and role substitutes, and submits revisions to CTO. Emergency deviations require an incident record and CTO review by the next business day; encryption exceptions remain subject to CD-ENC-001, including expiry within 90 days and monthly review. No active exception or approved contact directory is asserted.

Adoption review checklist

Before operational adoption, a human reviewer must validate staffing and alternate contacts, authority boundaries, cloud and SaaS inventories, available logging, evidence access, backup/key dependencies, customer contracts and jurisdiction-specific advice. Confirm consistency with the three related policies and record reviewer feedback and CTO approval. Current approval_status: not_recorded; review_status: requires_user_review. This sample supplies a proposed plan, not an incident history, operating-control evidence or certification.